

EC-Council



ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

MODULO
1

*Identity & Access
Management*

Identity & Access Management

Introduzione

- Abbiamo imparato che il sistema informatico è un insieme di fattori, tra cui possiamo subito collocare la raccolta dei dati e/o servizi. Tali elementi, devono assolutamente avere la garanzia di non essere violati nella loro

- ✓ Confidenzialità
- ✓ Riservatezza
- ✓ Integrità
- ✓ Disponibilità

- Per questo motivo, un qualsiasi utente che ha necessità di accedere a questo sistema informatico, deve superare uno sbarramento rappresentato così come segue:



Identity & Access Management

Identificazione

- Attraverso l'identificazione, l'utente, in quanto persona fisica, dichiara la sua identità alla macchina.
- Risponde alla domanda "Chi sei tu?". L'utente che vuole accedere ad un sistema, sia esso un computer, un server, un bancomat, deve "rispondere" a questa domanda. Nella maggior parte dei casi questa risposta è il login, username, user-id o la chiave pubblica. Questa informazione può anche essere **pubblica**, non coperta cioè da nessun vincolo di segretezza.
- Le procedure che assegnano credenziali senza un'opportuna identificazione rompono l'anello di congiunzione persona fisica → codici digitali che la rendono riconoscibile in rete

Identity & Access Management

Autenticazione

- Dopo aver dichiarato la propria identità, l'utente ha l'obbligo di dimostrare l'autenticità di quanto ha dichiarato. Per questo motivo, è richiesto l'inserimento (o dichiarazione) di un secondo elemento segreto che, in coppia con il valore dichiarato in fase di identificazione, possa restituire un



🔒 I sistemi o i metodi di autenticazione si basano su uno o più di questi cinque fattori:

- ✓ **Something you know** - Qualcosa che conosci, come password o PIN. Questo è spesso indicato come Tipo I.
- ✓ **Something you have** - Qualcosa che possiedi, come una smartcard, un token o un dispositivo di identificazione. Questo è spesso indicato come Tipo II.
- ✓ **Something you are** - Qualcosa che sei, come le impronte digitali o il modello retinico (spesso chiamato biometria). Questo è spesso indicato come Tipo III.
- ✓ **Something you do** - Qualcosa che fai, come un'azione da eseguire per completare l'autenticazione. Questo non ha un tipo (I, II, III).
- ✓ **Somewhere you are** - Da qualche parte (basato sulla geolocalizzazione). Questo non ha un tipo (I, II, III). A causa dell'uso del mobile computing, l'autenticazione "da qualche parte tu sei" non viene spesso utilizzato, poiché è Probabile che gli utenti effettuino l'accesso da località diverse. In effetti, molte fonti non includono "da qualche parte come sei" fattore di autenticazione.

Identity & Access Management

Single Factor Authentication (SFA)

- La forma più semplice di autenticazione è nota come autenticazione a fattore singolo (SFA), perché viene controllato solo un tipo di autenticazione. SFA è spesso implementata come la combinazione nome utente / password tradizionale. Un nome utente e una password sono identificativi univoci per una procedura di accesso.
- Ecco una sintesi di come funziona SFA: quando gli utenti si siedono di fronte di un sistema informatico, la prima cosa che un sistema di sicurezza richiede è che stabiliscano chi loro sono. L'identificazione viene generalmente confermata da un processo di accesso. La maggior parte dei sistemi operativi utilizza un ID utente (nome utente) e una password. Questi valori possono essere inviati attraverso la connessione come testo normale o possono essere crittografati.

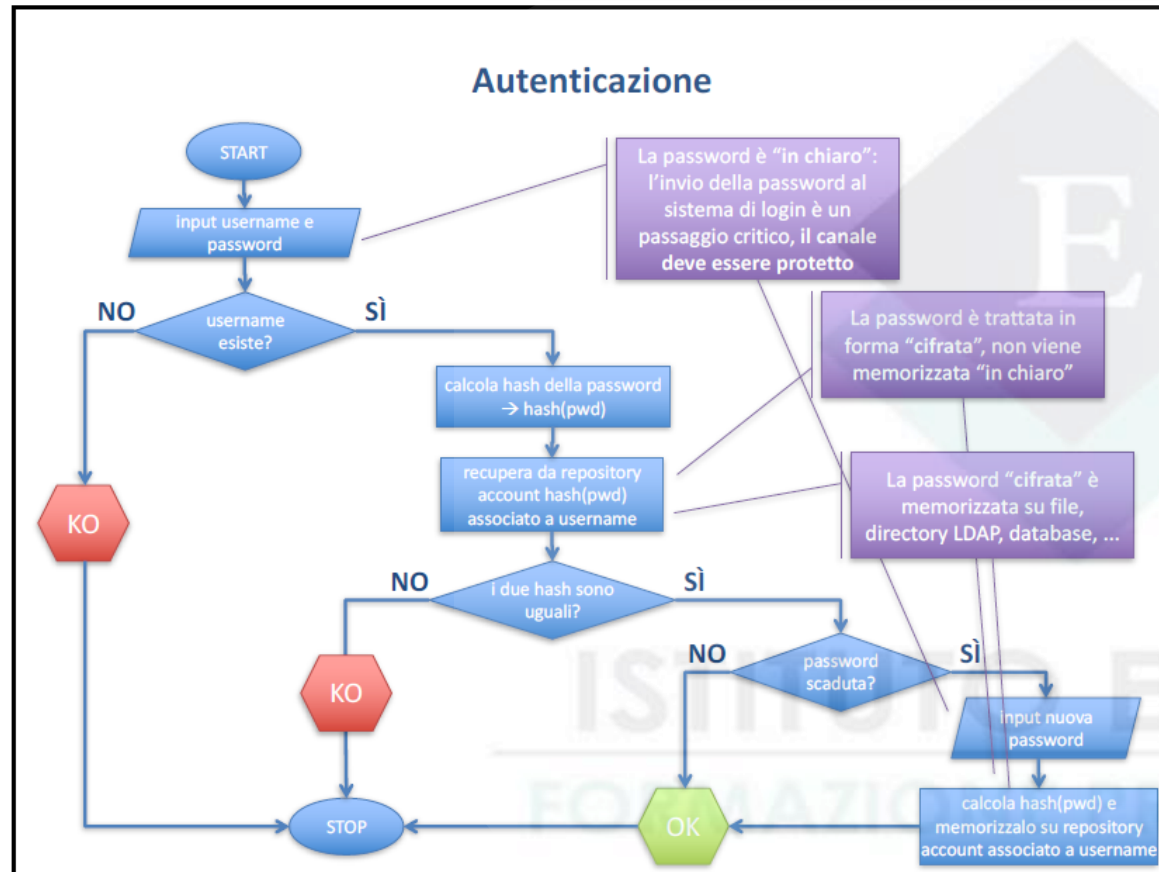


A screenshot of a web login form. At the top, the word "LOGIN" is displayed in bold. Below it, there are two input fields: "Email Address:" and "Password:". Each field has a placeholder text "Enter your Email Address" and "Enter your password" respectively, and a small asterisk icon on the right. At the bottom of the form, there are two buttons: a blue "SIGNUP" button and a green "LOGIN" button.



Identity & Access Management

Single Factor Authentication (SFA)



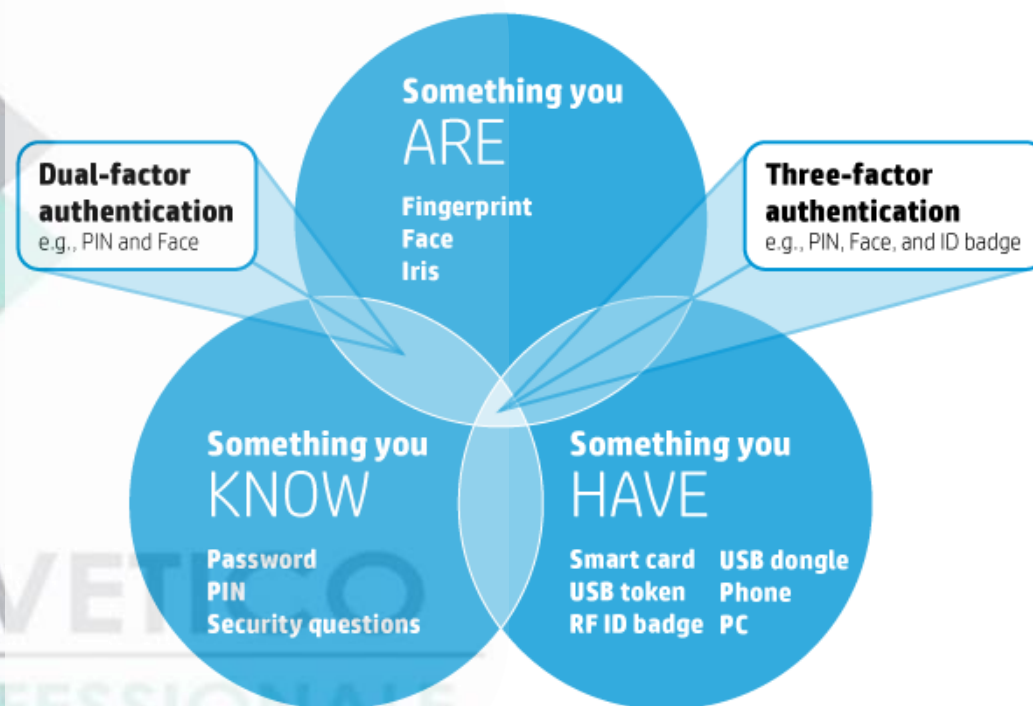
- 🔒 Schema logico di un processo di autenticazione, basato su username e password (con hash della password).
- 🔒 Attraverso l'autenticazione reciproca, due o più parti si autenticano reciprocamente.
 - ✓ Un client può autenticarsi su un server e un server può autenticarsi su un client quando è necessario stabilire una sessione sicura tra i due e utilizzare la crittografia.
 - ✓ L'autenticazione reciproca garantisce che il client non si connetta e fornisca involontariamente le sue credenziali a un server canaglia, che può quindi girarsi e rubare i dati dal vero server.
- 🔒 Normalmente, l'autenticazione reciproca verrà implementata quando i dati saranno inviati durante la sessione è di natura critica, come i registri finanziari o medici.

Identity & Access Management

Multifactor Authentication

- Quando due o più metodi di accesso sono inclusi come parte del processo di autenticazione, stai implementando un sistema di autenticazione multifactor. Un sistema che utilizza le smartcard e le password sono indicate come un sistema di autenticazione a due fattori.
- Un sistema multifactor può essere anche costituito da due o più fattori. Per ovvi motivi, i due o più fattori impiegati non dovrebbero essere dello stesso categoria.

Multi-factor authentication



Identity & Access Management

Federation

- Col termine Federation, si indica una raccolta di computers networks, che utilizzano gli stessi standard operativi, come ad esempio gli standard in materia di sicurezza.
 - ✓ Talvolta, si parla di Federation anche nell'ambito di messaggistica istantanea (IM), con la quale, più provider concordano ed usano gli stessi standard per l'erogazione del servizio.
 - ✓ Altro caso, in cui un gruppo di aziende partner o professionisti, concordano standard di sicurezza comune. Questo facilita la comunicazione tra i dipendenti di ciascun partner.
- Quindi, se parliamo di Federated Identity, indichiamo il sistema con cui sono collegate le identità di ogni utente (appartenente a partner federati), con i suoi privilegi, in modo da poter operare anche fuori dal proprio confine aziendale. Ciò consente a un utente di avere un'unica identità che può utilizzare in modo diverso in ogni business unit.

ATTENZIONE:

✓ La *Federated Identity*, non va confusa con la *single sign-on* e con la *same sign-on*

Federated Identity

- Possibilità di accedere a risorse su reti diverse

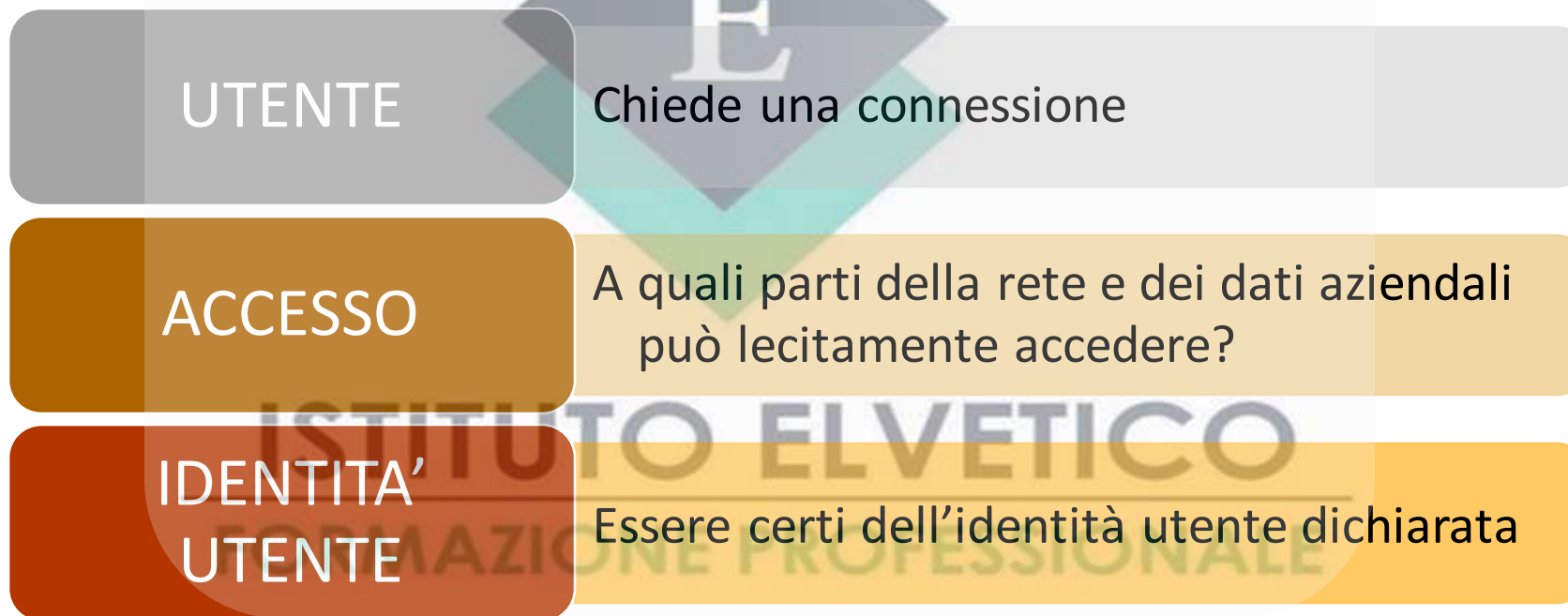
Single Sign-ON

- Utilizzo di una sola autenticazione per tutte le risorse o servizi di un singolo fornitore (Es: Google Suite, servizi Microsoft, servizi Apple)

Same Sign-ON

- Opzione che permette di utilizzare un provider esterno di autenticazione per accedere a una risorsa terza (Es: servizi SAML-security assertion markup language-, login con Facebook account in siti non legati a Facebook)

- Se l'autenticazione è il processo che consente al sistema di verificare l'identità di un utente, tale operazione può avvenire sia su un singolo computer che in una rete di computer.





Autenticazione di rete

Sistemi LDAP

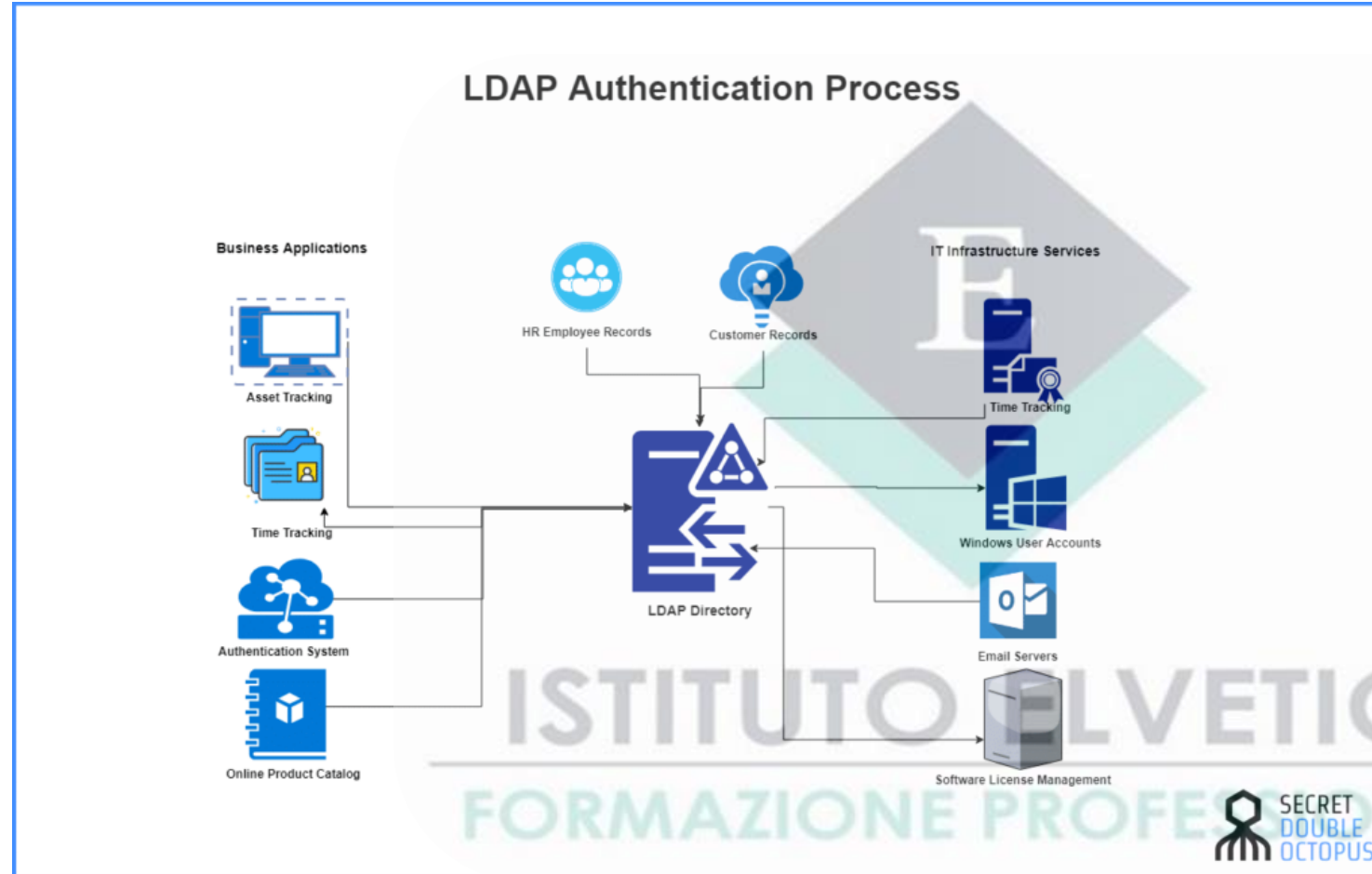
- Spesso nasce l'esigenza di avere, in azienda, un numero elevato di servizi informatici eterogenei e distribuiti, che talvolta si risolve con la creazione di innumerevoli account su macchine diverse e per scopi diversi.
- La soluzione sta nella possibilità di centralizzare la gestione delle utenze, facendo uso delle tecnologie LDAP (Lightweight Directory Access Protocol), organizzando le informazioni attraverso una scala gerarchica usando le directory. Queste informazioni possono essere specifiche per una singola autenticazione o essere usate per abilitare chiunque ad accedere al proprio account da una qualsiasi macchina:
 - ✓ È un protocollo di accesso alle directory, che consente di creare query su directory (basate su standard X.500).
 - ✓ È un sistema Client/Server. All'inizio della procedura di autenticazione, interviene un client LDAP
 - ✓ È il protocollo di accesso principale utilizzato da Active Directory.
 - ✓ Funziona in predefinito sulla porta 386
 - ✓ Per la sua sintassi, utilizza le virgole tra i nomi
 - ✓ Un server LDAP violato, è per le aziende che lo implementano, un problema molto serio. Per questo motivo, si ricorre al LDAPS, in cui tutte le trasmissioni sono crittografate con SSL / TLS (usa la porta 636)



ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

Autenticazione di rete

Sistemi LDAP



Sistemi LDAP: Binding Strings

- 🔒 Per accedere alle proprietà e ai metodi di un oggetto, in un sistema LDAP è necessario associarlo. Questo crea un riferimento all'oggetto. L'associazione agli oggetti di Active Directory con un'istruzione "Set", utilizzando il metodo GetObject. GetObject richiede una "stringa di associazione", ovvero una stringa di testo che specifica in modo univoco l'oggetto in Active Directory. Questo è anche indicato come AdsPath dell'oggetto.

- ✓ Set objUser = GetObject("LDAP://cn=Joe Smith,ou=East,dc=MyDomain,dc=com") Set objComputer =
- ✓ GetObject("LDAP://cn=Test2,cn=Users,dc=MyDomain,dc=com") Set objGroup =
- ✓ GetObject("LDAP://cn=Engr,ou=East,dc=MyDomain,dc=net") Set objOU =
- ✓ GetObject("LDAP://ou=Sales,ou=East,dc=MyDomain,dc=MyFirm,dc=com")

LDAP:	The provider (case sensitive)
objUser, objComputer, objGroup, objOU	Variable referring to the object
cn=Joe Smith,ou=East,dc=MyDomain,dc=net	Distinguished Name of user "Joe Smith"
cn=Joe Smith	Relative Distinguished Name of user "Joe Smith"
dc=MyDomain,dc=com	DNS domain name (MyDomain.com)
cn=Users	Relative Distinguished Name of container "Users"
ou=East	Organizational Unit where user "Joe Smith" resides
cn	Common Name
ou	Organizational Unit
dc	Domain Component

CHAP – Challenge Handshake Authentication Protocol

- Challenge Handshake Authentication Protocol è un protocollo di autenticazione con cui gli utenti inviano il loro user ID e password al server (criptato, ovviamente). Prima di compiere questa operazione, il server autentica l'utente. Quindi una volta che l'autenticazione è completata,
- il server indirizza il computer client a generare un numero casuale (spesso un hash crittografico) da inviare al server (anche crittografato, ovviamente).
- Poi il server periodicamente sfiderà il client per riprodurre quel numero / hash. Se la sessione client è stata compromessa, il client non sarà in grado di produrre quel numero / hash, e il server chiuderà la sessione. Microsoft ha una versione proprietaria di questo chiamato MS-CHAP.

EAP – Extensible Authentication Protocol

- EAP è un protocollo di autenticazione come PAP (Password Authentication Protocol) e CHAP (Challenge Handshake Authentication Protocol). A differenza di questi due, tuttavia, EAP è un protocollo di autenticazione generale che può supportare diversi e molteplici metodi di autenticazione tra cui OTP (One Time Password), TLS (Transport Layer Security), CHAP, ecc. senza dover prima pre-negoziarne uno in particolare.
 - ✓ EAP tipicamente si basa direttamente su protocolli di livello data-link come PPP (Point to Point Protocol) o su IEEE 802, senza la necessità di avere IP.
 - ✓ È un framework solitamente usato nelle reti wireless e connessioni Point-to-Point
- Ci sono diverse versioni di EAP:
 - ✓ LEAP (Lightweight Extensible Authentication) è stato sviluppato da Cisco (ampiamente utilizzato nelle comunicazioni wireless). LEAP è supportato da molti sistemi operativi Microsoft, incluso Windows 7.
 - ✓ EAP-TLS (Extensible Authentication Protocol - Transport Layer Security) Questo protocollo utilizza TLS al fine di proteggere il processo di autenticazione. La maggior parte delle implementazioni di EAP-TLS utilizza Certificati digitali X.509 per l'autenticazione degli utenti.
 - ✓ PEAP (Protocollo di autenticazione estensibile protetto) Questo protocollo crittografa l'autenticazione elaborando un tunnel TLS autenticato. PEAP è stato sviluppato da un consorzio comprendente Cisco, Microsoft e RSA Security. È stato prima incluso in Microsoft Windows XP.
 - ✓ EAP FAST (Autenticazione veloce o flessibile tramite Tunneling sicuro) È stato proposto questo protocollo da Cisco in sostituzione dell'originario EAP. EAP-FAST stabilisce un tunnel TLS per l'autenticazione, ma lo fa utilizzando una PAC (credenziale di accesso protetto).

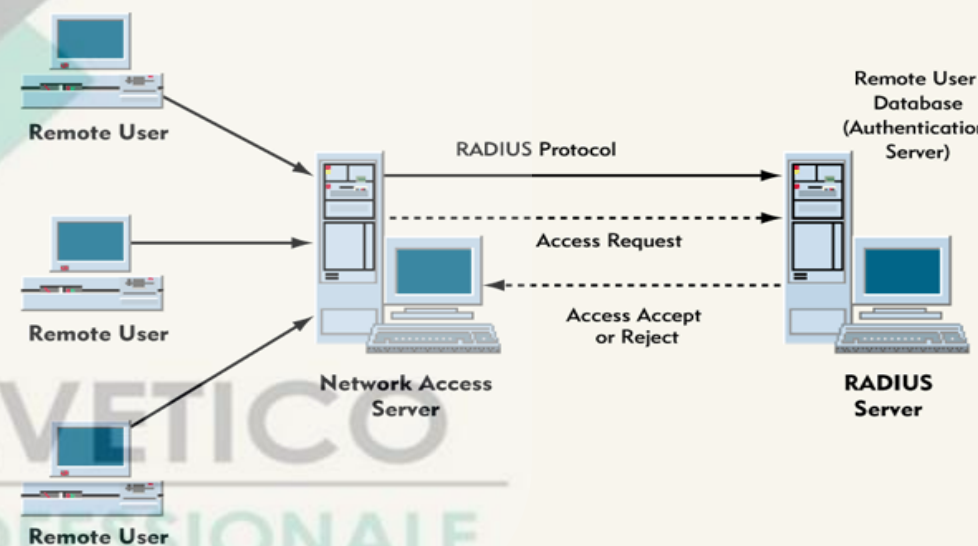
Autenticazione di rete

Standard 802.1x

- EAP viene anche utilizzato con 802.1.x, lo standard IEEE per la rete basato su controllo accesso porta. Può essere utilizzato su una LAN o una WLAN.
- Di seguito viene riportata una descrizione semplificata di come funziona l'autenticazione 802.1X.
 - ✓ Un client invia a un punto di accesso un messaggio di "richiesta di accesso". Il punto di accesso richiede l'identità del client.
 - ✓ Il client risponde inviando il pacchetto contenente la propria identità, che viene quindi trasmesso al server di autenticazione.
 - ✓ Il server di autenticazione invia al punto di accesso un pacchetto di "accettazione".
 - ✓ Il punto di accesso cambia lo stato della porta del client che viene autorizzata a far passare il traffico di dati.
- Il client wireless dà inizio a una richiesta di autenticazione 802.1X presso un punto di accesso, il quale esegue l'autenticazione del client a un server RADIUS compatibile con EAP. Il server RADIUS può autenticare l'utente (tramite password o certificati) o il sistema (tramite l'indirizzo MAC). In teoria, al client wireless non è consentito far parte della rete finché la transazione non è completata. (Non tutti i metodi di autenticazione utilizzano un server RADIUS. WPA-Personale e WPA2-Personale utilizzano una password comune che deve essere inserita sul punto di accesso e su tutte le periferiche che richiedono l'accesso alla rete.)

RADIUS – Remote Authentication Dial-in User Service

- Remote Authentication Dial-In User Service (RADIUS) è un meccanismo che consente l'autenticazione remota e altre connessioni di rete. Originariamente previsto per essere usato su connessioni dial-up, si è mosso ben oltre e offre molte funzionalità all'avanguardia. Il protocollo RADIUS è uno standard IETF ed è stato implementato dalla maggior parte dei principali produttori di sistemi operativi.
- Un server RADIUS può essere gestito centralmente, e i server che consentono l'accesso a una rete possono verificare con un server RADIUS se un chiamante in entrata è autorizzato. In una grande rete con molte connessioni, questo consente a un server singolo, di eseguire tutte le autenticazioni.



RADIUS – Remote Authentication Dial-in User Service

- 🔒 RADIUS (Remote Authentication Dial-In User Service) è un protocollo client-server AAA (Authorization, Authentication, Accounting) utilizzato quando un client AAA remoto esegue la procedura di accesso o di chiusura della sessione da un server di accesso alla rete (NAS). I server RADIUS sono in genere utilizzati dai provider di servizi Internet (ISP) per eseguire operazioni di tipo AAA. Le fasi AAA sono le seguenti:
- ✓ **Fase di autenticazione:** consente di verificare il nome utente e la password confrontandoli con le informazioni contenute in un database locale. Completata la verifica delle credenziali, ha inizio il processo di autorizzazione.
 - ✓ **Fase di autorizzazione:** consente di determinare se viene concessa la richiesta di accesso a una risorsa. Al client remoto viene assegnato un indirizzo IP.
 - ✓ **Fase di registrazione:** consente la raccolta di informazioni sull'utilizzo delle risorse allo scopo di effettuare analisi di tendenza, controlli, riepiloghi delle prestazioni orarie della sessione e allocazioni dei costi

TACACS – Terminal Access Controller Access Control System

- Terminal Access Controller Access Control System (TACACS) è orientato ad un ambiente client-server e funziona in modo simile al RADIUS. TACACS esteso (XTACACS) ha sostituito la versione originale e ha combinato l'autenticazione e l'autorizzazione con la registrazione. Il metodo o il livello più recente di TACACS è TACACS + che sostituisce il precedente. TACACS + consente l'accettazione delle credenziali da più metodi, incluso Kerberos. Il processo client-server TACACS si realizza nello stesso modo del Processo RADIUS. Cisco ha ampiamente implementato TACACS+.
- TACACS+ è diventato ampiamente accettato come alternativa a RADIUS.

ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE



Autenticazione di rete

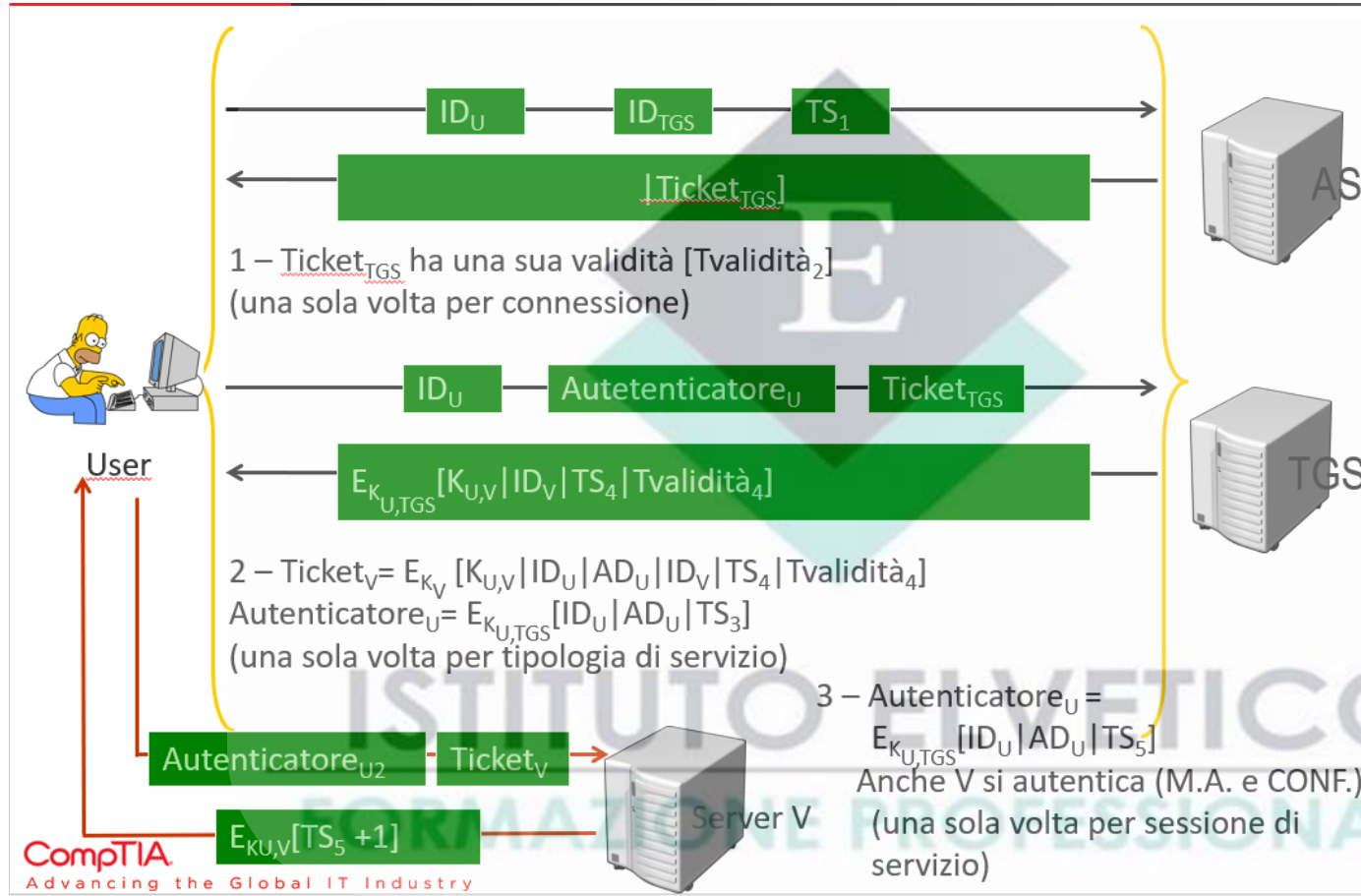
Kerberos: un po' di storia

- Realizzato dal MIT negli anni '70 per il progetto ATHENA in alternativa al sistema di autenticazione tradizionale. Le autorità degli USA classificarono Kerberos come parte degli asset militari e ne vietarono l'esportazione poiché utilizzava l'algoritmo di crittazione DES a 56 bit progettato dal NSA (National Bureau of Standard) per rendere più sicure informazioni non classificate ma ugualmente delicate. Negli anni 2000 il Royal Institute of Technology svedese ha progettato una successiva versione libera dalle imposizioni statunitensi.
- Il nome KERBEROS deriva dal mito greco di Cerbero, il cane a 3 teste = Kerberos 3 moduli:
 - ✓ Authentication: un servizio che consente di accertare l'identità dichiarata da una entità mediante la verifica di credenziali.
 - ✓ Authorization: Protegge l'accesso ad una risorsa mediante l'applicazione di "Security Policy".
 - ✓ Audit: Registrazione di eventi di sistema o di rete. Consente di rintracciare, ricostruire l'utilizzo delle risorse.
 - ✓ Kerberos fornisce una mutua identificazione tra utente e fornitore del servizio avvalendosi di una terza parte affidabile che si occupa della distribuzione delle chiavi crittografiche (KDC - Key Distribution Center). Il KDC consta di due parti logiche (in genere sulla stessa macchina): AS (authentication server) e TGS (Ticket Granting Server). Kerberos usa dei "biglietti" (ticket) per convalidare l'identità degli utenti.



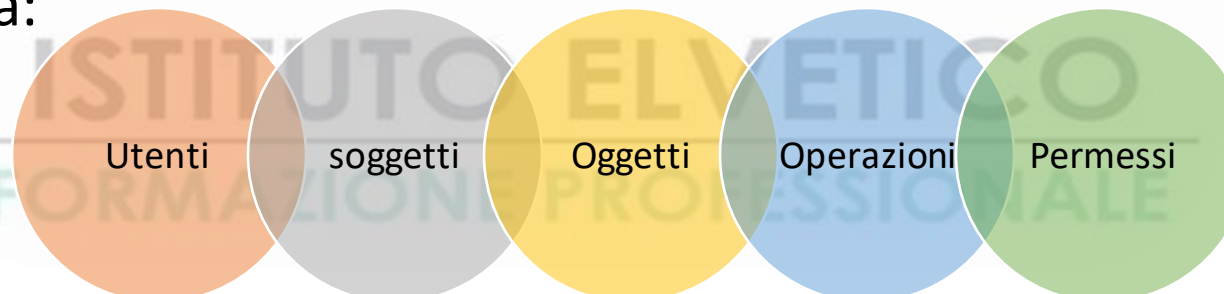
ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE





- Una volta che il sistema ha accertato l'identità dichiarata dall'utente, verificata con i passaggi di autenticazione visti precedentemente, ora si tratta di stabilire «cosa l'utente può fare», ossia a quali risorse, a quali dati puoi accedere.
- Questo passaggio, è garantito con un controllo agli accessi, in base alle autorizzazioni precedentemente date al profilo dell'utente. Il sistema è pertanto in grado di stabilire quali operazioni consentire e quali vietare all'utente.
- Le logiche prese in considerazione dai sistemi informatici, possono essere:
 - ✓ Mandatory Access Control
 - ✓ Discretionary Access control
 - ✓ Role-Based Access Control
 - ✓ Rule-Based Access Control
 - ✓ Attribute-based Access Control (ABAC)

- Un sistema di controllo degli accessi riguarda:
 - ✓ il modo in cui gli utenti accedono alle risorse di un sistema
 - ✓ “Who can do what”
- Ha un ruolo centrale nel mantenimento dei requisiti di:
 - ✓ Riservatezza (Confidentiality)
 - ✓ Integrità (Integrity)
 - ✓ Disponibilità (Availability)
- Generalmente, un modello di controllo degli accessi può essere definito usando le seguenti entità:



MAC – Mandatory Access Control

- Il MAC prevede di etichettare tutti i dati con un livello di sicurezza quando vengono inseriti nel sistema.
 - ✓ Il livello di sicurezza, si basa su SECURITY POLICY MILITARI (basato sulla protezione dei dati, in cui ogni informazione viene classificata con un particolare livello di importanza

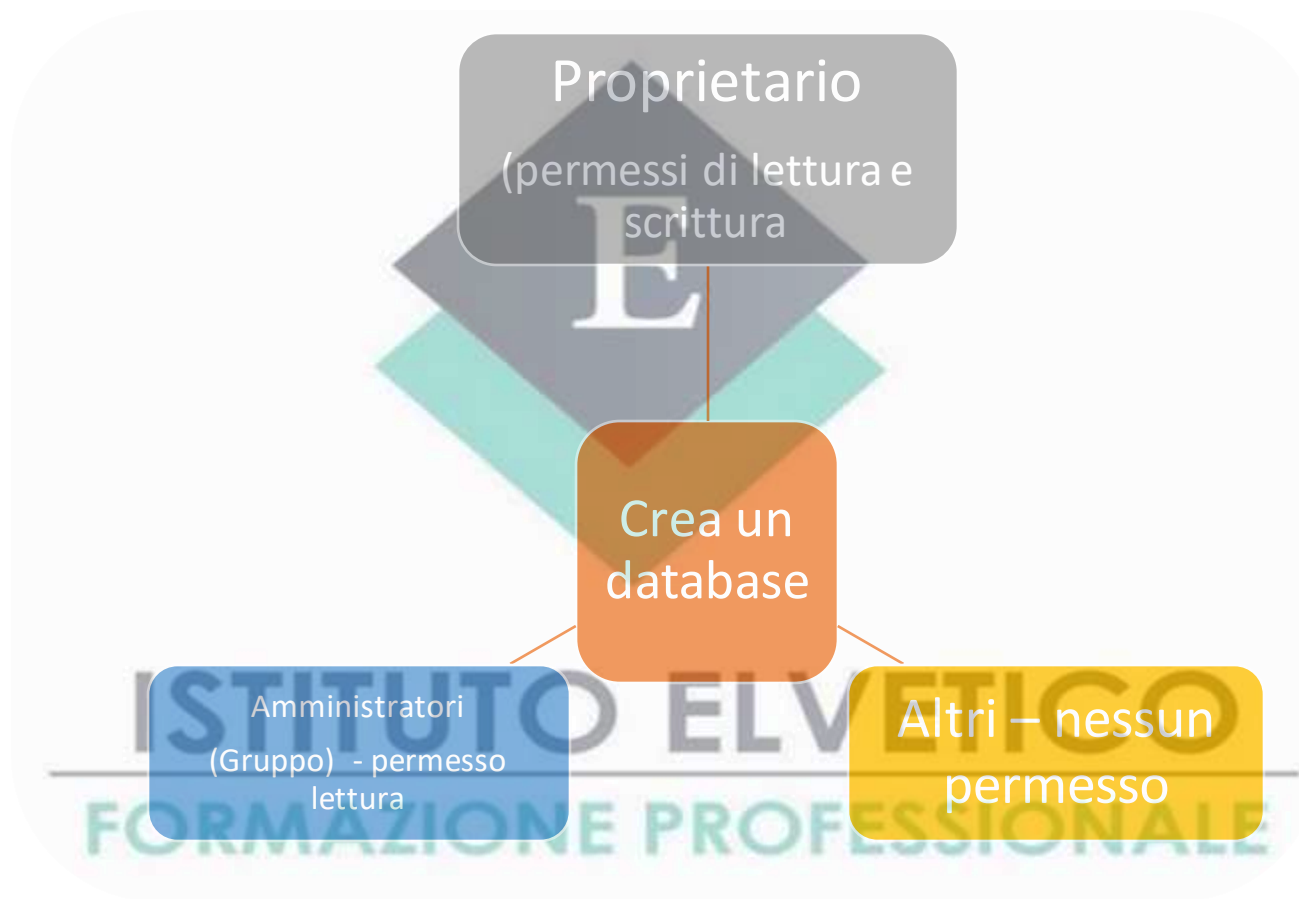


DAC – Discretionary Access Control

- Secondo il modello DAC, ciascuna risorsa ha un proprietario (che talvolta coincide con il suo creatore), il quale assegna gli accessi ad altri, a sua discrezione.
- Questo modello, da un lato consente agli utenti di condividere le informazioni in modo dinamico con altri utenti, ma dall'altro, crea un ambiente più flessibile nel quale è più alto il rischio di divulgazione non autorizzata di informazioni. Questo, quindi diventa il principale compito degli amministratori i quali devono assicurare un accesso ai dati appropriato.
- Un classico esempio di DAC è la struttura dei permessi che esiste per i file "altri" in Ambiente Unix / Linux. Tutte le autorizzazioni in questo sistema operativo rientrano in tre gruppi di utenti: proprietario, gruppo e altro. Le autorizzazioni associate al proprietario e al gruppo a cui appartiene il proprietario si basa sui suoi ruoli, ma tutti quelli che non sono proprietario o membro del gruppo rientrano nella categoria dell'altro.

Autorizzazione

DAC – Discretionary Access Control



DAC – Discretionary Access Control

- Una implementazione tipica di modello DAC, è nei permessi di file e cartelle su dischi con filesystem NTFS.
- Il filesystem, è un insieme di informazioni che, in un sistema operativo tipo Windows, permette al sistema operativo stesso di accedere ai contenuti delle repository (file e cartelle) nel disco stesso.
- Il filesystem NTFS, introdotto da Microsoft in occasione della distribuzione della versione Windows NT, ha permesso una condivisione delle risorse controllata e gestita dall'utente grazie ai permessi utente.

ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

RBAC – role-based Access Control

- Role-based access control (RBAC) affrontano il problema del controllo dell'accesso basato su ruoli stabiliti all'interno dell'organizzazione. in funzione al lavoro svolto dall'utente o alla sua responsabilità. Se un utente si sposta da un ruolo a un altro, l'accesso per il ruolo precedente non sarà più disponibile. Pertanto modelli RBAC offrono una maggiore flessibilità rispetto al modello MAC e meno flessibilità rispetto al modello DAC.
- Invece di pensare "Denise deve essere in grado di modificare i file", RBAC utilizza la logica "Editor «deve essere in grado di modificare i file "e" Denise è un membro del gruppo Editors ".
- Questo modello è ritenuto valido in un ambiente in cui vi è un elevato turnover dei dipendenti.

RBAC – role-based Access Control

- Rule-based Access Control (RBAC) utilizza regole del tipo:
 - ✓ Rifiuta tutti tranne quelli che rientrano in una lista (una lista di permessi)
 - ✓ Rifiuta solo quelli che appaiono in uno specifico elenco (un vero elenco di negazione)
- Le voci nell'elenco possono essere nomi utente, indirizzi IP, nomi host o anche domini. Questi modelli vengono spesso utilizzati in combinazione con modelli basati sui ruoli per aggiungere più flessibilità.
- Il modo più semplice per implementare il controllo degli accessi basato su regole è con una implementazione di elenchi di controllo di accesso (ACL)

ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE



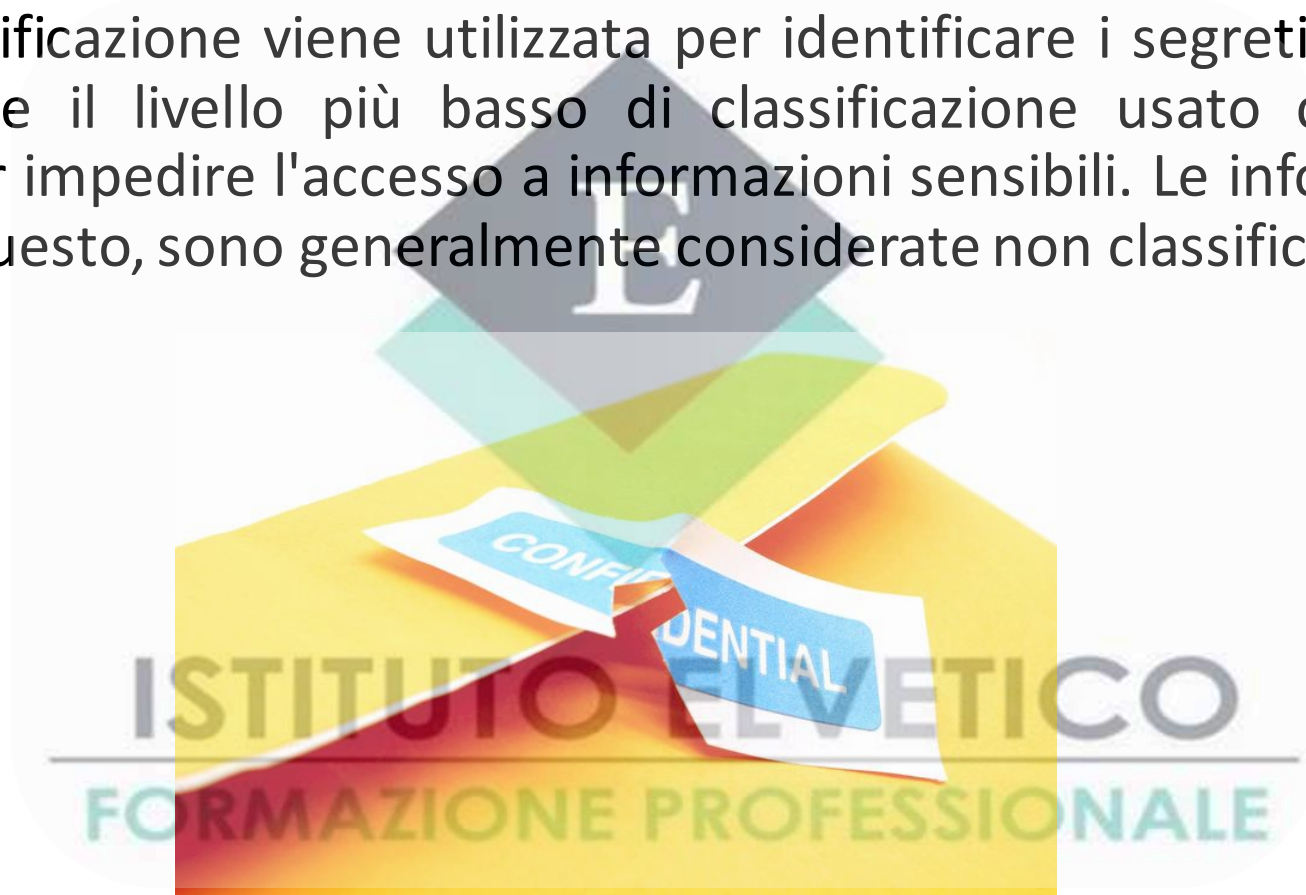
ABAC – Attribute-based Access Control

- Il controllo degli accessi basato sugli attributi (ABAC) è un metodo relativamente nuovo per il controllo degli accessi. Secondo questo standard: Una metodologia di controllo di accesso logico in cui l'autorizzazione a eseguire un insieme di operazioni è determinato valutando gli attributi associati all'oggetto.
- In sostanza, il meccanismo di controllo esamina i soggetti che stanno tentando di accedere ad un determinato oggetto ma considera tutti i vari attributi associati all'oggetto. Un soggetto è un'entità attiva (generalmente un individuo, processo o dispositivo). Un oggetto è una risorsa a cui si sta tentando accedere. Gli attributi sono caratteristiche che definiscono aspetti specifici del soggetto, oggetto, condizioni ambientali.
- Se, ad esempio, un rappresentante di vendita itinerante sta tentando di accedere ai record dei clienti su una rete aziendale, un sistema ABAC non guarderebbe solo il diritto di accesso dell'utente, ma valuterebbe l'intero scenario.
 - ✓ È il rappresentante che effettua l'accesso da una macchina?
 - ✓ o da una posizione?
 - ✓ È un lui o una lei?
 - ✓ L'accesso sta avvenendo in un momento insolito?
- In sostanza, ABAC è una metodologia di controllo degli accessi più robusta che esamina l'intero scenario nel prendere una decisione sul controllo degli accessi.

Date Sensitivity Labeling and Handling

Confidential

- Questa classificazione viene utilizzata per identificare i segreti di basso livello; è generalmente il livello più basso di classificazione usato campo militare. È utilizzato per impedire l'accesso a informazioni sensibili. Le informazioni di livello inferiore a questo, sono generalmente considerate non classificate.



Date Sensitivity Labeling and Handling

Private

- Le informazioni private sono intese solo per uso interno all'organizzazione. Sono informazioni che se divulgate, potrebbero svelare segreti commerciali o influenzare negativamente il personale. Sono considerate informazioni private, quelle generate durante il flusso di produzione dell'azienda, come ad esempio documenti di lavoro.
- Le informazioni interne comprendono i registri del personale, i documenti di lavoro finanziari, i registri, elenchi di clienti e qualsiasi altra informazione necessaria per la gestione di un'impresa. Una impropria divulgazione, crea problemi di responsabilità.

ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

Date Sensitivity Labeling and Handling

Public

- Le informazioni pubbliche sono principalmente rese disponibili al pubblico più vasto o a individui specifici. Ad esempio, i rendiconti finanziari di un'organizzazione privata potrebbero essere informazioni disponibili pubblicamente, oppure solo a individui o organizzazioni che ne hanno un legittimo bisogno. La cosa importante da tenere a mente è che un'organizzazione deve sviluppare politiche sulle quali le informazioni sono disponibili e per quali scopi saranno diffuse.
- Le informazioni di tipo Limited Distribution, sono informazioni non destinate al pubblico. Questa categoria di informazioni è di tipo privato. Se una società sta cercando di ottenere una linea di credito, le informazioni fornite a una banca sono di natura privata. Questa informazione, se divulgata a concorrenti, potrebbe dare loro un'idea dei piani dell'organizzazione o della sua salute finanziaria. Se divulgato ai clienti, potrebbe spaventarli e farli passare ad un concorrente.

Date Sensitivity Labeling and Handling

PII – PHI - PROPRIETARY

- 🔒 **Personally Identifiable Information (PII)** sono tutti i dati che possono essere usati per identificare un individuo in modo univoco. Questi dati possono essere ad esempio, il nome della persona, un'impronta digitale (nel caso della biometrica), un numero di carta di credito o il record di un paziente.
- 🔒 **Personal Health Information (PHI)** sono più comunemente conosciute come informazioni sanitarie protette e dovrebbero essere considerate come un sottoinsieme di informazioni personali da proteggere. Secondo la legge degli Stati Uniti, ad esempio, PHI è qualsiasi informazione sullo stato di salute di un individuo, dati che favoriscono la fornitura di assistenza sanitaria.
- 🔒 **Proprietary** - etichetta spesso utilizzata con dati relativi alle operazioni aziendali. Come tale, di solito è sinonimo di riservatezza e dovrebbe essere trattato con attenzione e cura.



Date Sensitivity Labeling and Handling

Data Roles

- 🔒 Un individuo spesso può avere ruoli diversi su file diversi. I sistemi operativi per computer e i sistemi operativi di rete offrono molte scelte. Tre sono i ruoli importanti:
 - ✓ Owner - Quando si tratta di dati, il proprietario è la persona (o le persone) identificata (per legge, contratto, o politica) con la responsabilità di garantire l'accesso agli utenti e garantire un uso appropriato delle informazioni. Di solito, questa è la persona che ha creato il file, ma non è un requisito necessario.
 - ✓ Steward/Custodian - L'amministratore, cioè la persona (o le persone) operativamente responsabili per la sicurezza fisica ed elettronica dei dati. In genere, questo è l'amministratore di sistema, l'amministratore di database o il programmatore / analista. Nella gran parte delle aziende, i dipendenti amministrativi condividono il ruolo di amministratore delle informazioni, mentre nelle piccole unità aziendali il ruolo potrebbe essere svolto da una persona dell'IT department.
 - ✓ Privacy Officer – o responsabile della privacy è l'addetto alla privacy, spesso conosciuto come chief privacy officer (CPO); è la persona all'interno di un'organizzazione incaricata di salvaguardare le informazioni personali. Nelle organizzazioni mediche, l'individuo è incaricato della protezione delle cartelle cliniche del paziente per rimanere conforme con lo standard imposto da HIPAA (Legge sulla Portabilità e Responsabilità delle Assicurazioni Sanitarie), mentre in ambito finanziario organizzazioni, salvaguardano le transazioni finanziarie e bancarie dei consumatori in conformità con il Fair Credit Reporting Act e il Gramm-Leach-Bliley Act, tra gli altri.

FORMAZIONE PROFESSIONALE

Date Sensitivity Labeling and Handling

Date Retention – Conservazione dei dati

- Un aspetto significativo sulla gestione dei dati, riguarda soprattutto il periodo di conservazione degli stessi. A tal proposito, è opportuno prendere in considerazione la normativa vigente nel nostro Stato. Fermo restando poi che ogni azienda, deve avere al suo interno una politica di conservazione dei dati per delineare le linee guida, anche da un punto di vista operativo, per il mantenimento delle informazioni.
- Il GDPR, al quale facciamo in Italia riferimento, in realtà, non ha introdotto un elemento di innovazione sostanziale rispetto al vecchio Codice Privacy (D.lgs. 196/2003), che già prevedeva all'articolo 11 che i dati personali devono essere:
 - ✓ ***“conservati in una forma che consenta l'identificazione dell'interessato per un periodo di tempo non superiore a quello necessario agli scopi per i quali essi sono stati raccolti o successivamente trattati”.***
- Anche chi si occupa di sicurezza delle informazioni avrà sicuramente sentito parlare di *data retention*, espressione che si riferisce perlopiù al tempo di conservazione dei dati di backup: l'arco di tempo in cui un backup è disponibile per il ripristino ovvero per quanto tempo i dati salvati andranno conservati prima di essere cancellati.

Date Sensitivity Labeling and Handling

Termini di conservazione dei dati

- Alcuni termini di conservazione sono determinati direttamente dalla legge o da un contratto mentre altri sono autodeterminati dal titolare del trattamento.
- Quando il punto di partenza per l'identificazione è il dettato legislativo, deve essere applicato un requisito già determinato.
 - ✓ A dicembre 2017, per esempio, il legislatore ha modificato gli obblighi in carico agli operatori telefonici portando il periodo di conservazione dei dati di traffico telefonici e telematici a 72 mesi (periodo massimo).
- In taluni casi invece la legge è di supporto per identificare il periodo minimo di conservazione: ad esempio, nella valutazione potrebbe essere utile partire dai termini di prescrizione entro i quali un soggetto esterno può attivare un'azione nei confronti del titolare del trattamento. A questi sarebbe necessario aggiungere un ulteriore periodo – cuscinetto utile per tener conto anche del deposito e della notifica di un atto giudiziario.
 - ✓ Un'azienda, volendo sintetizzare un caso pratico, potrebbe decidere di conservare i dati relativi al rapporto di lavoro minimo per 10 anni.

Date Sensitivity Labeling and Handling

Diritto all'oblio – art. 17 GDPR

- 🔒 Il diritto all'oblio è un istituto che si riferisce alla cancellazione dei dati personali. Secondo questo articolo, quindi, l'interessato ha il diritto di ottenere dal titolare del trattamento la cancellazione dei dati personali che lo riguardano senza ingiustificato ritardo, e il titolare del trattamento ha l'obbligo di cancellare senza ingiustificato ritardo i dati personali se:
- ✓ I dati non sono più necessari per le finalità per le quali sono stati raccolti
 - ✓ L'interessato revoca il consenso su cui si basa il trattamento e non sussiste altro motivo legittimo per trattare i dati.
 - ✓ L'interessato si oppone al trattamento dei dati personali e non sussiste alcun motivo legittimo prevalente per procedere al trattamento
 - ✓ I dati sono stati trattati illecitamente
 - ✓ I dati devono essere cancellati per adempiere un obbligo legale previsto dal diritto dell'Unione o degli Stati membri cui è soggetto il titolare del trattamento
 - ✓ I dati sono stati raccolti a minori di età.